Nom : WIDAMOU YANDA

NIVEAU : MASTER 2

FILIERE : SISD

EXERCICE I : CHAPITRE 1

Ex. 1.1 Diagnostic de maturité

Pour évaluer la maturité de **LiZbiZ-SIS**, nous nous basons sur la grille fournie (Tab. 1.3).

- **Niveau de maturité : 2**
  - **Justification :** L'entreprise possède l'infrastructure. Cependant, la détection semble encore basée sur des alertes génériques sans règles métier spécifiques, plaçant l'entité au-dessus du niveau initial 1.
- **Actions correctives prioritaires :**
  - **Réduction du MTTD (Temps moyen de détection) :** Passer d'une fenêtre de 2–7 jours à moins de 24 heures en configurant un système d'alerte en temps réel sur les actifs critiques (AD, ERP).
  - **Définition d'un processus de triage :** Établir une procédure de levée de doute pour réduire le taux de faux positifs (FPR) et ne plus traiter les alertes de manière "non triée".

Ex. 1.2 Sélection de sources

Voici la priorisation des 5 sources logiques pour maximiser la visibilité sur les menaces :

Priorité	Sources	Menaces détectables
1	WINDOWS ad	Vols D'identifiants, élévation de privilèges, attaque par force brute
2	Firewall pfSense	Scan des ports, connexion vers des adresses IP dangereux
3	Proxy squid	Navigtion dans les sites de pillage des données (phishing), telechargement de virus
4	Serveur ERP (windows)	Acces non autorisé au données de l'entreprise, modification de la DATABASE
5	Linux Apache	Injection SQL, scan de vulnérabilité web

Ex. 1. 3 Règle de corrélation

Voici une regle de corrélation au format Sigma :

```
title: Détection Mouvement Latéral SMB (Multi-Serveurs)
status: experimental
description: Détecte un utilisateur se connectant à plus de 3 serveurs distincts via SMB en moins de 5 minutes.
logsource:
  product: windows
  service: security
detection:
  selection:
    EventID: 4624 # Connexion réussie
    LogonType: 3 # Réseau (SMB)
  filter_servers:
    TargetOutboundUserName: '*'
    ComputerName:
      - 'SRV-*' # Masque pour cibler les serveurs
  condition: selection | count(ComputerName) by TargetOutboundUserName > 3
  timeframe: 5m
falsepositives:
  - Scripts d'administration légitimes
  - Scans d'inventaire réseau (type GLPI ou SCCM)
level: high # Niveau de gravité
tags:
  - attack.lateral_movement
- attack.t1021.002 # Mapping MITRE ATT&CK
```

EXERCICE II : CHAPITRE 2

Ex. 2. 2 Configuration Rsyslog

Afin de configurer l'envoi des journaux vers le SIEM, nous allons éditer le fichier /etc/rsyslog.d/50-siem.conf

```
$ActionQueueType LinkedList
$ActionQueueFileName siem_queue
$ActionQueueMaxDiskSpace 1g
$ActionQueueSaveOnShutdown on
$ActionQueueResumeRetryCount -1
$ActionQueueDequeueBatchSize 10000

### Envoi des journaux de niveau warning et supérieur (*.warning)
### Protocole TCP  vers 10.0.0.5 port 6514
*.warning  @@(o)10.0.0.5:6514
```

Ex. 2. 3 Analyse de la timeline

En analysant l'extrait de la timeline de l'incident LiZbiZ-SIS du 12/04/2026 dans le Tab 2.6 :

a) Durée entre le premier scan et la première connexion réussie :

- Premier scan (pfSense) : **02:47:11**
- Première connexion réussie (SSH user: backup) : **03:14:51**
- **Calcul :** 03:14:51 - 02:47:11 = **27 minutes et 40 secondes.**

b) EID confirmant l'effacement :

- L'événement de suppression des journaux (T1070.001) sur `srv-erp-01` correspond à l'**EID 1102** (Microsoft Windows Security Auditing - The audit log was cleared).

c) Technique MITRE du mouvement latéral :

- La technique est **T1021.002** (Remote Services: SMB/Windows Admin Shares). Elle est visible à 03:21:15 lors du passage de `srv-web-01` vers `srv-erp-01`.

d) Deux mesures qui auraient interrompu la chaîne dès l'étape 3 : L'étape 3 est l'authentification SSH réussie (Brute force réussi). Pour l'interrompre :

1. **Verrouillage de compte (Fail2Ban) :** Après les 7 échecs détectés à 03:14:22, l'IP source `203.0.113.42` aurait dû être bannie automatiquement, empêchant la connexion réussie 29 secondes plus tard.

2. **Authentification Multi-Facteurs (MFA) :** Même avec un mot de passe découvert par force brute, l'attaquant aurait été bloqué par l'absence du second facteur de validation sur le service SSH.